

Mapeo de Indicadores / Preguntas a Requisitos Normativos y Marcos

Nota: MITRE ATT&CK es un marco técnico, no una norma de cumplimiento, pero se integra con NIS2, DORA, ENS, ISO 27001 y NIST CSF como base para métricas y capacidades.[web:66][web:52]

Indicador / Pregunta GQM principal	ATT&CK / Concepto	Norma / Marco relacionado (ejemplos)	Comentario
I1: Cobertura de tácticas ATT&CK prioritarias	Tácticas ATT&CK (Txxxx)	NIS2 (capacidad de detección), ENS (medidas de protección), NIST CSF Detect	Mide capacidades mínimas frente a amenazas frecuentes. [web:66][web:43]
Q1.1/Q1.2 sobre tácticas prioritarias por sector	Priorización TTP sectoriales	ENISA Threat Landscape, marcos nacionales de ciberestrategia	Alinea métricas con panorama de amenazas europeo.[web:66] [web:61]
I2: Cobertura de técnicas ATT&CK relevantes	Técnicas ATT&CK (Txxxx)	NIST CSF Detect (DE.AE), ISO 27001 A.8, ENS medidas de operación	Traduce requisitos de detección en cobertura de técnicas concretas.
Q2.1 sobre técnicas relevantes	CTI + ATT&CK	ENISA ETL, NIS2 gestión de riesgos, DORA amenazas TI	Exige uso de inteligencia de amenazas para identificar técnicas clave.[web:66]
I3: Brecha cobertura declarada vs validada	Validación de controles	NIST CSF Respond (RS.TE), ENS pruebas de seguridad, ISO 27001 mejora	Respaldado por necesidad de pruebas periódicas y mejora continua.
Q3.2/Q3.3 sobre ejercicios y validación	Red/purple teaming, pruebas ATT&CK	ENS ejercicios de respuesta, NIS2 capacidades operativas	Refuerza obligación de testear capacidades, no sólo declararlas.
I4: Calidad de detección (falsos positivos / contexto)	Detección y análisis	NIST CSF Detect (DE.CM, DE.AE), ISO 27035 gestión de incidentes	Mejora eficacia de SOC y tiempos de respuesta.
I5: % alertas críticas etiquetadas con ATT&CK	Etiquetado ATT&CK	NIS2 reporting de incidentes, ENS registro de eventos	Facilita reporting homogéneo a autoridades nacionales y europeas.
I6: MTTD, MTTC, MTTR por táctica/técnica crítica	Tiempos de respuesta	NIS2 (respuesta y notificación), DORA continuidad, NIST CSF Respond/Recover	Relevante para plazos de notificación y recuperación.
Q6.3 sobre comparación con objetivos nacionales	Benchmarks mínimos	Guías de autoridades competentes (AN, CERT), reguladores sectoriales	Permite fijar umbrales y SLAs mínimos sectoriales.
I7: Uso de CTI con mapeo ATT&CK y priorización ENISA	CTI y TTP	NIS2 intercambio de información, NIST CSF Detect (DE.CM), ENISA ETL	Favorece ecosistemas de CTI y cooperación público-privada. [web:66][web:43]

I8: % incidentes mapeados a ATT&CK y distribución táctica	Análisis táctico de incidentes	ISO 27035, NIS2 notificación, ENS gestión de incidentes	Mejora calidad del reporting y las lecciones aprendidas.
I9: % herramientas y servicios gestionados alineados con ATT&CK	Capacidades de proveedores	DORA (gestión de terceros TI), NIS2 cadena de suministro	Permite exigir capacidades mínimas a MSSP y proveedores. [web:16][web:23]
I10: Índice Global de Madurez ATT&CK (IGM)	Madurez global	NIST CSF Govern, modelos de madurez nacionales	Soporta evaluación macro de resiliencia y comparaciones entre sectores.
I11: ROI de iniciativas ATT&CK-driven	Economía de ciberseguridad	NIS2 gestión de riesgos, DORA costes y resiliencia financiera	Ayuda a justificar inversiones ante reguladores y órganos de gobierno.[web:50][web:53]